



Australian Privacy Principles

Guidelines | Privacy Act 1988 (Cth)

Office of the Australian Information Commissioner

[PRIVACY LAW STUDY NOTES]

"The APPs set out standards, rights and obligations for how organisations must collect, hold, use and disclose personal information in Australia."

WHAT'S INSIDE

APP 1–2 Transparency

APP 3–5 Collection

APP 6–7 Use & Marketing

APP 8–9 Cross-Border

APP 10 Data Quality

APP 11 Security

APP 12 Access

APP 13 Correction



Yadav Ghorasainee

[linkedin.com/in/yadav-ghorasainee](https://www.linkedin.com/in/yadav-ghorasainee)
yadavgybernet.github.io/sec/

What are the Australian Privacy Principles

APP Overview — Privacy Act 1988 (Cth)

- 13 legally binding principles governing personal information
- Administered by the Office of the Australian Information Commissioner
- Applies to most Australian Government agencies and large businesses
- Also applies to private sector orgs with turnover over AUD \$3 million

Key Objectives:

- Protect the privacy of individuals' personal information
- Set clear rules for collection, use, storage and disclosure
- Give individuals rights to access and correct their own data

Who Must Comply?

- All Australian Government agencies — no threshold
- Private sector businesses with annual turnover > AUD \$3 million

EXAMPLE:

A major Australian bank collects customer data for loan applications.

Under the APPs, they must tell customers WHY they are collecting it,

HOW it will be used, and who it may be disclosed to — before or at collection.

APP 1 & 2: Transparency & Anonymity

APP 1 — Open and Transparent Management

- Organisations must have a clearly written Privacy Policy
- Policy must be freely available — accessible on request or online
- Must describe: what info is collected, why, and how it is managed
- Policy must also cover overseas disclosure and complaint process

APP 2 — Anonymity and Pseudonymity

- Individuals must have the option to deal anonymously where practical
- Or use a pseudonym — a name other than their true legal identity
- Exception: if the law requires identity or it is impractical to do so

Why APP 1 & 2 Matter:

- Transparency builds customer trust and reduces regulatory risk
- Anonymity protects individuals from unwanted profiling and targeting

EXAMPLE:

A government health portal allows citizens to submit feedback anonymously. Their Privacy Policy (APP 1) clearly states data is used only for service improvement and is never disclosed to third parties without consent.

APP 3, 4 & 5: Collection & Notification

APP 3 — Collection of Solicited Personal Information

- Only collect information that is reasonably necessary for your function
- Must collect directly from the individual wherever reasonably possible
- Sensitive information requires explicit consent before collection

APP 4 — Dealing with Unsolicited Information

- If you receive personal info you did not ask for — assess it immediately
- If it could not have been collected under APP 3 — destroy or de-identify it

APP 5 — Notification at Collection

- Notify individuals at or before the point of collection
- Must inform: identity, purpose, consequences of not providing info
- Must advise if info will be disclosed to overseas recipients

EXAMPLE:

Online retailer's checkout form collects address and payment details.

APP 5: A collection notice must appear — stating who collects the data, why it is needed, and that it will NOT be sold to third-party marketers.

APP 6 & 7: Use, Disclosure & Marketing

APP 6 — Use or Disclosure of Personal Information

- Use or disclose only for the primary purpose it was collected
 - Secondary use requires individual consent or a permitted exception
 - Exceptions: law enforcement, serious threats, legal proceedings
- Cannot share customer data with marketers without clear consent

APP 7 — Direct Marketing

- Organisations may only use personal info for direct marketing if:
 - The individual would reasonably expect it — AND — opted in
 - Every marketing communication must include a clear OPT-OUT option
 - Once opt-out is received, marketing must cease immediately
- Cannot use sensitive information for direct marketing — ever

Key APP 7 Rule:

EXAMPLE:

Gym collects member email for billing but sends weekly promo emails.

APP 7 violation: Email was collected for billing — not marketing purposes.

Fix: Include opt-in checkbox at sign-up AND an unsubscribe link every email.

APP 8 & 9: Cross-Border & Identifiers

APP 8 — Cross-Border Disclosure of Personal Information

- Before disclosing info overseas, take reasonable steps to ensure
 - the overseas recipient's country has comparable privacy protection
 - Or obtain the individual's informed consent for overseas transfer
- The disclosing organisation remains accountable for overseas breaches

Permitted Overseas Disclosure Conditions:

- Binding contractual agreement requiring APP-equivalent protection
- Individual expressly consents after being advised of the risk
- Disclosure required or authorised by Australian law or court order

APP 9 — Government Related Identifiers

- Organisations must NOT adopt government identifiers as their own
- Cannot use TFN, Medicare number, or passport number as a customer ID

EXAMPLE:

Australian HR company stores employee records on a US cloud server.

APP 8: Company must ensure the US provider contractually meets

APP-equivalent standards — or obtain written employee consent first.

APP 10 & 11: Data Quality & Security

APP 10 — Quality of Personal Information

- Take reasonable steps to ensure personal info is accurate,
- up-to-date, complete and not misleading before use or disclosure
- This obligation is strongest just before the data is used or disclosed
- Outdated or incorrect records must be updated proactively

APP 11 — Security of Personal Information

- Must protect personal information from misuse, interference and loss
- And from unauthorised access, modification or disclosure
- Implement reasonable technical and organisational security measures
- Encryption, access controls and audit logs are expected controls

Destruction & De-identification (APP 11.2):

- When data is no longer needed for any permitted purpose:

EXAMPLE:

Insurance company stores 10-year-old customer claim records on an open share.

APP 10: Records must be reviewed — outdated info corrected or flagged.

APP 11: Records no longer needed must be securely destroyed, not just archived.

APP 12 & 13: Access & Correction

APP 12 — Access to Personal Information

- Individuals have the right to access their personal information
- Organisation must respond to access requests within 30 days
- Must provide access in the requested format where reasonably practical
- A fee may be charged — but must not be excessive or a deterrent

Grounds to Refuse Access (limited):

- Unlawful — e.g. would reveal another person's information
- Serious threat to life, health or safety of any person
- Prejudice to enforcement of Australian or foreign law

APP 13 — Correction of Personal Information

- Individual can request correction of inaccurate, outdated or incomplete data
- Organisation must correct it OR note the request alongside the record

EXAMPLE:

Customer requests access to all personal data held by a telco company.
 APP 12: Telco must provide it within 30 days in a readable format.
 Customer finds wrong address — APP 13: Telco must correct it and notify any third parties (e.g. credit bureau) that received the wrong address.

Notifiable Data Breaches Scheme

NDB Scheme — Privacy Act 1988 (Part IIIC)

- Mandatory reporting scheme in force since 22 February 2018
- Applies to all entities covered by the Australian Privacy Act
- Requires notification when a qualifying data breach occurs

What is an Eligible Data Breach?

- Unauthorised access, disclosure or loss of personal information
- That is likely to result in serious harm to individuals affected
 - Financial harm, reputational damage, physical safety, discrimination

Notification Requirements:

- Notify the OAIC (Office of the Australian Information Commissioner)
- Notify all affected individuals as soon as practicable
- Notification must describe: breach, data involved, recommended steps

EXAMPLE:

Hacker accesses healthcare provider's system — 50,000 patient records exposed. Provider must assess risk of serious harm within 30 days of awareness. If serious harm is likely: notify OAIC AND all 50,000 affected individuals, describing what happened and what protective steps they should take.

Penalties & Enforcement

Privacy Act 1988 — Regulatory Powers

Civil Penalties (as of 2023 amendments):

- Serious or repeated interference with privacy:
 - Up to AUD \$50 million for corporations
 - OR 3× the benefit obtained from the breach — whichever is greater
 - OR 30% of adjusted turnover during the breach period
- For individuals: up to AUD \$2.5 million

OAIC Enforcement Powers:

- Accept enforceable undertakings from entities
- Conduct assessments and investigations — own initiative or complaint
- Apply to the Federal Court for civil penalty orders
- Issue determinations including compensation to individuals

EXAMPLE:

Australian company suffers breach exposing 9.8 million customer records. OAIC investigates — finds inadequate security measures (APP 11 breach). Federal Court orders AUD \$50 million penalty and mandatory privacy audit. Real case: Optus 2022 data breach — OAIC launched formal investigation.

Key Takeaways

APP Compliance Core Flow:



All 13 APPs — Quick Reference:

- APP 1 Open & Transparent APP 2 Anonymity
- APP 3 Collection APP 4 Unsolicited Info
- APP 5 Notification APP 6 Use & Disclosure
- APP 7 Direct Marketing APP 8 Cross-Border
- APP 9 Gov Identifiers APP 10 Data Quality
- APP 11 Security APP 12 Access
- APP 13 Correction of Data

Core Principles to Remember:

- Only collect what is necessary — purpose limitation is fundamental

Thanks for Reading!

Save for reference · Share with your network · Apply the APPs!

[linkedin.com/in/yadav-ghorasainee](https://www.linkedin.com/in/yadav-ghorasainee) | yadavgybernet.github.io/sec/